

## A DoS attack occurred in run-llama/llama\_index due to inappropriate secure coding measures in run-llama/llama\_index

✓ Valid

Reported on Feb 2nd 2025

### Description

A DoS vulnerability has been identified in the KnowledgeBaseWebReader class of the run-llama/llama\_index project, and this issue has been reported (see the link below):

- Huntr Report : <https://huntr.com/bounties/27883f22-35ff-49df-aaa5-05031c7d6ad8>

However, due to the developer's inappropriate mitigation, the DoS vulnerability still persists. As a result, an attacker can perform a DoS attack using the same payload as reported in the link above.

### The source code of the KnowledgeBaseWebReader class containing the issue

```
def get_article_urls(
    self, browser: Any, root_url: str, current_url: str, max_depth: int = 100
) -> List[str]:
    """
    Recursively crawl through the knowledge base to find a list of articles.

    Args:
        browser (Any): a Playwright Chromium browser.
        root_url (str): root URL of the knowledge base.
        current_url (str): current URL that is being crawled.

    Returns:
        List[str]: a list of URLs of found articles.

    """
    page = browser.new_page(ignore_https_errors=True)
    page.set_default_timeout(60000)
    page.goto(current_url, wait_until="domcontentloaded")

    # If this is a leaf node aka article page, return itself
    if self.article_path in current_url:
        print("Found an article: ", current_url)
        page.close()
        return [current_url]
```

```

# Otherwise crawl this page and find all the articles linked from it
article_urls = []
links = []

for link_selector in self.link_selectors:
    ahrefs = page.query_selector_all(link_selector)
    links.extend(ahrefs)

for link in links:
    url = root_url + page.evaluate("(node) => node.getAttribute('href')", link)
    article_urls.extend(
        self.get_article_urls(browser, root_url, url, max_depth)
    )

page.close()

return article_urls

```

Please refer to the previously reported [Huntr Report link](#) for details on why this code leads to a DoS vulnerability.

The developer attempted to prevent the DoS vulnerability by adding `max_depth: int = 100`, but the secure coding measure was not properly implemented.

As the loop progresses, the `max_depth` value should increment, and execution should terminate when the threshold is reached. However, the current code lacks logic for increasing the threshold or executing the termination process.

```

def get_article_urls(
    self, browser: Any, root_url: str, current_url: str, max_depth: int, depth: int
) -> List[str]:
    # Execution terminates when max_depth is reached.
    if depth >= max_depth:
        print(f"Reached max depth ({max_depth}): {current_url}")
        return []

    for link in links:
        href = page.evaluate("(node) => node.getAttribute('href')", link)
        if href:
            url = root_url + href if href.startswith("/") else href

            # The depth increases by +1 on each recursive call.
            article_urls.extend(
                self.get_article_urls(browser, root_url, url, max_depth, depth + 1)
            )

    page.close()
    return article_urls

```

## Patch Recommendation

It is recommended to modify the value of `max_depth` as the loop progresses, as shown above. When the threshold is reached, the program should either terminate or raise an exception.

## Impact

This vulnerability can exhaust Python's recursion limit through repeated function calls, leading to resource consumption and ultimately crashing the Python process.

## Occurrences

 `base.py` L129-L170

 We are processing your report and will contact the `run-llama/llama_index` team within 24 hours. a year ago

 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists a year ago



**huntr-helper** has marked this vulnerability as a duplicate of `27883f22-35ff-49df-aaa5-05031c7d6ad8` a year ago

\$ The disclosure bounty has been dropped 

\$ The fix bounty has been dropped 

★ The researcher's credibility has decreased: -5



**huntr-helper** commented a year ago

**Admin**

This report was closed because it was determined to be a duplicate of a report submitted on 2024-10-28 04:42:27.900000

 A huntr admin reset this report to a pending state. a year ago



**Freedom of the Mind** commented a year ago

**Researcher**

Hello, is the review of the above content in progress?



**Massimiliano Pippi** validated this vulnerability a year ago

The researcher is right, fix wasn't effective.

\$ **freedom-of-the-mind** has been awarded the disclosure bounty 

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 CVE-2025-1752 assigned to this report. a year ago



Massimiliano Pippi commented a year ago

[https://github.com/run-llama/llama\\_index/pull/17949](https://github.com/run-llama/llama_index/pull/17949)



 A `run-llama/llama_index` maintainer has acknowledged this report a year ago

 The scheduled publication date was automatically extended from 3rd May 2025 to 10th May 2025 due to the maintainers acknowledgement of the report a year ago



 Massimiliano Pippi marked this as fixed in `0.3.6` with commit `3c65db` a year ago

\$ Massimiliano Pippi has been awarded the fix bounty 

\$ `base.py#L129-L170` has been validated 

 We have notified the `run-llama/llama_index` maintainers about this report in their weekly follow-up 9 months ago

 We have sent a warning to the `run-llama/llama_index` team to inform them that this report will be published in 48 hours 9 months ago



A `run-llama/llama_index` maintainer commented 9 months ago

Maintainer

Fyi, the title of this issue is not accurate. This affects a specific package in our monorepo, not the entire repo or main package

`llama-index-readers-web` in `llama-index-integrations/readers/llama-index-readers-web`

 This vulnerability has now been published 9 months ago

 CVE-2025-1752 has now been published 9 months ago

[Sign in](#) to join this conversation

CVE  
CVE-2025-1752  
Published

Vulnerability Type  
CWE-674: Uncontrolled Recursion

Severity

High (7.5)

|                     |           |
|---------------------|-----------|
| Attack vector       | Network   |
| Attack complexity   | Low       |
| Privileges required | None      |
| User interaction    | None      |
| Scope               | Unchanged |
| Confidentiality     | None      |
| Integrity           | None      |
| Availability        | High      |

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

~ latest(v0.12.15)

Visibility

Public

Status

Fixed

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



Freedom of the Mind

@freedom-of-the-mind

MIDDLEWEIGHT



Fixed by



Massimiliano Pippi

@masci

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



